

TSEC Risk & Cyber Advisory LLC

Integrated Cybersecurity, Risk & Compliance Advisory

GUIDE-HIPAA-02

HIPAA Risk Assessment Guide

Conducting an OCR-Compliant Risk Analysis for ePHI Under the HIPAA Security Rule

TSEC Compliance Insights | HIPAA Series

Document ID:	GUIDE-HIPAA-02
Version:	2026 Edition
Effective Date:	June 2026
Classification:	CONFIDENTIAL
Prepared by:	TSEC Risk & Cyber Advisory LLC

TSEC Compliance Insights | TSEC Risk & Cyber Advisory LLC | www.tsecgrc.com | info@tsecgrc.com

1. Why the Risk Assessment Is the Foundation of HIPAA Compliance

The HIPAA Security Rule's Risk Analysis requirement (45 CFR 164.308(a)(1)(ii)(A)) is not just one of many security requirements — it is the cornerstone on which all others rest. The Risk Analysis tells you which risks exist; Risk Management tells you how you've decided to address them; and the security safeguards you implement are the tools you've selected based on those decisions. Without an adequate Risk Analysis, your HIPAA security program lacks a rational foundation.

The U.S. Department of Health and Human Services' Office for Civil Rights (OCR) has made this clear through enforcement: failure to conduct an adequate, enterprise-wide Risk Analysis is the most frequently cited violation in HIPAA enforcement actions. Penalties have reached into the millions of dollars for organizations that never conducted a Risk Analysis — and for those that conducted one but failed to act on its findings.

2. What Makes a Risk Analysis 'Adequate'?

OCR guidance, HHS guidance documents, and enforcement actions provide a consistent picture of what an adequate Risk Analysis must include.

Requirement	What OCR Looks For
Scope: Enterprise-wide	The analysis must cover all ePHI that the organization creates, receives, maintains, or transmits — not just the EHR system, and not just systems the IT team manages. This includes medical devices, mobile devices, cloud services, home health equipment, and any other location where ePHI might reside.
Threats and Vulnerabilities Identified	The analysis must identify reasonably anticipated threats to ePHI — including human threats (malicious and accidental), natural threats, and technical/environmental threats. For each threat, corresponding vulnerabilities must be identified.
Likelihood Determined	For each threat/vulnerability combination, the analysis must assess the likelihood of the threat exploiting the vulnerability.
Impact Assessed	For each risk, the potential impact to the confidentiality, integrity, and availability of ePHI must be assessed, including harm to individuals.
Risk Level Assigned	Based on likelihood and impact, each risk must receive an overall risk level that supports prioritization of risk management activities.
Documented	The entire analysis, including methodology, findings, and risk levels, must be documented and retained for 6 years.

3. Conducting the Risk Analysis: A Step-by-Step Approach

Step 1: Identify the Scope

Start by inventorying all systems, devices, locations, and workflows that create, receive, maintain, or transmit ePHI. This is where many organizations discover ePHI in places they didn't expect: physician laptops without encryption, cloud storage used by staff without IT awareness, legacy applications not covered by the EHR vendor's BAA, and medical devices that transmit patient data wirelessly.

Step 2: Identify Threats

For each system or category of systems, brainstorm reasonably anticipated threats. Use current threat intelligence, HHS OCR's top breach causes, and your own incident history as inputs. Common threats include: ransomware; phishing and credential compromise; lost or stolen devices; insider misuse or snooping; misconfigured systems exposing ePHI; vendor breaches; and physical break-ins.

Step 3: Identify Vulnerabilities

For each threat, identify the vulnerabilities it could exploit. Run vulnerability scans on in-scope systems. Review configurations against security baselines. Assess whether current safeguards are designed and operating effectively. Consider people vulnerabilities (undertrained staff, shared passwords) alongside technical ones.

Step 4: Assess Likelihood and Impact

Use your chosen rating scale (typically a 3- or 5-point scale for each dimension) to score likelihood and impact. Combine them to produce a risk level. Be honest: inflating control effectiveness to lower risk scores undermines the purpose of the analysis and creates liability if the optimistic assumptions prove wrong.

Step 5: Prioritize and Treat Risks

High-risk items require prompt action. Medium risks require a documented treatment plan. Low risks should be monitored. For each risk, document the selected treatment (mitigate, accept, transfer) and, for mitigation decisions, the specific controls to be implemented. This treatment documentation is your Risk Management record required by 45 CFR 164.308(a)(1)(ii)(B).

4. Risk Analysis vs. Risk Assessment: Terminology Note

HIPAA uses the term 'Risk Analysis.' Other frameworks (ISO 27001, NIST) use 'Risk Assessment.' They refer to the same process. If your organization follows NIST's Risk Assessment guidance (e.g., NIST SP 800-30), that methodology is compatible with HIPAA's Risk Analysis requirement — just ensure the output specifically addresses ePHI confidentiality, integrity, and availability.

5. How Often Must the Risk Analysis Be Conducted?

The Security Rule requires the Risk Analysis to be conducted 'periodically' — a deliberately flexible standard. At minimum, conduct a full review annually and update the analysis whenever there are significant changes to the environment, such as: new systems or applications that handle ePHI; mergers or acquisitions bringing new ePHI environments; new Business Associate relationships; significant security incidents; and changes in the regulatory environment that affect what constitutes adequate security.

6. The Most Common Risk Analysis Failures

Failure Mode	What It Looks Like	How to Avoid It
--------------	--------------------	-----------------

Insufficient scope	Analysis covers the EHR but not laptops, mobile devices, cloud storage, or medical devices	Build a complete ePHI inventory before beginning the analysis; update it with every new system or tool
Generic threats not tailored to the environment	Analysis lists 'unauthorized access' without considering the specific systems, their vulnerabilities, or the attackers relevant to healthcare	Use threat intelligence specific to healthcare and your technology stack; reference OCR's breach report data
Risk analysis as a one-time event	Analysis conducted for HIPAA certification purposes and never updated, despite significant changes to systems and staff	Build risk analysis into your annual compliance calendar; update on an ongoing basis for significant changes
Completed but not acted upon	Risks identified but no treatment plans implemented; the same risks appear in successive annual analyses without progress	Tie risk analysis outputs directly to a treatment plan with owners, timelines, and tracking

7. Key Takeaways

- The HIPAA Risk Analysis is the cornerstone of HIPAA Security Rule compliance — without it, the rest of your security program lacks a rational foundation
- An adequate Risk Analysis must be enterprise-wide, covering all ePHI wherever it resides, not just the primary EHR system
- The analysis must identify threats and vulnerabilities, assess likelihood and impact, and produce documented risk levels
- Risk Analysis findings must be acted upon — a well-documented analysis that was never implemented is itself an enforcement risk
- Update the analysis periodically (at least annually) and whenever significant changes occur to systems, staff, or the regulatory environment

8. Using the HHS Security Risk Assessment Tool

HHS offers a free Security Risk Assessment (SRA) Tool designed to help small and medium-sized healthcare providers conduct the HIPAA risk analysis required by 45 CFR 164.308(a)(1). The tool walks users through: identifying ePHI locations and flows; identifying threats and vulnerabilities; assessing likelihood and impact; and generating a report summarizing findings. While the tool is valuable for smaller organizations, larger or more complex organizations typically need a more customized approach that can address their specific technology environments, patient volumes, and business models.

9. Documenting Your Risk Analysis: What to Include

OCR expects to see detailed documentation of the risk analysis process, not just a summary of findings. A well-documented risk analysis includes:

Documentation Element	What to Include
Methodology description	How risks were identified (interviews, system review, vulnerability scanning, prior audit findings); who participated; the likelihood and impact scales used; how risk levels were determined

Scope statement	A statement confirming that the analysis covers all ePHI wherever it is created, received, maintained, or transmitted, or a clear explanation of any boundaries and their justification
Asset / ePHI inventory	List of all systems, devices, locations, and workflows that contain or handle ePHI, used as the basis for threat identification
Threat and vulnerability inventory	For each asset or asset category, the threats considered and vulnerabilities identified, with source references (e.g., vulnerability scan results, configuration review findings, industry threat intelligence)
Likelihood and impact scores	The scores assigned to each threat/vulnerability combination, with brief rationale for each score
Risk level determination	The overall risk level derived from likelihood and impact, and how it will be prioritized in the Risk Management plan
Current safeguards considered	A description of existing controls taken into account when scoring likelihood — important for distinguishing between inherent and residual risk
Date of analysis and next review date	To demonstrate currency and planning for periodic review

10. Connecting Risk Analysis to the Security Rule's Addressable Specifications

As discussed in the HIPAA Security Rule Guide, 'Addressable' implementation specifications require the organization to assess whether they are reasonable and appropriate for its environment. The risk analysis is the tool you use to make that determination: if your risk analysis identifies a risk that the addressable specification would mitigate, the specification is almost certainly 'reasonable and appropriate,' and you must implement it.

Document the connection explicitly in your risk analysis. For each addressable specification you determine to be not reasonable and appropriate, your documentation should reference the risk analysis findings that support that conclusion — not just state that the specification is 'not applicable' without basis. This documentation is what protects the organization if OCR ever questions the determination.